SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

*I **Sweety Roselin 192324164** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

CO1-AT3-ASSIGNMENT

1) Ambiguous Scope and Unlisted Vulnerable Systems

- **Strict Adherence to Scope & Written Authorization:-**
A one line authorization email is legally hazardous. Penetration testing requires an explicit contract. Without the system explicitly enumerated in writing, testing or exploiting it breaches stated computer fraud statutes
- **Principles of least Harm**: Exploitation carries an inherent risk of service distribution, data corruption or triggering unintend-ed cascading failures, especially on an asset whose function and criticality are unknown.
- **Duty to disclose**: Ethical hackers have a fiduciary and ethical obligation to inform the client immediately rather than leveraging an unvetted entry point.

CORRECT ACTION:

Cease testing on that target, document the discovery and contact the clients authorized technical liaison to report the critical exposure and formalize the scope.

2) Live customer data & SQL injection

Stop data dumps: Immediately halt automated or table-wide exfiltration tools (sqlmap --dump, UNION extracts)

Benign PoC Only: Prove execution with harmless meta data or non-destructive time delays (Select @@version, pg_sleep(3))

Report & Redact: Alert the client immediately about exposed PII / finance data, mask sensitive records in logs / screenshots and encrypt notes.

Pre-engagement precautions:

- Mandate testing on isolated staging / UAT environment with sanitized synthetic data.
- Define contractual handling rules for PII/PEI data and set hard exploitation ceilings in the rules of engagement.

3) Accidential Denial-of-Service

Immediate Response:

Kill the tooling: Abort all scans, scripts and threads instantly.

Call Emergency POC: Directly telephone the 24/7 technical lead - do not rely on email.

Triage & assist: Provide source IP, timestamp, target and the offending payload; help infrastructure teams unblock resources or restart services

Root-cause Memo: Document why the root cause occured and revise test parameters

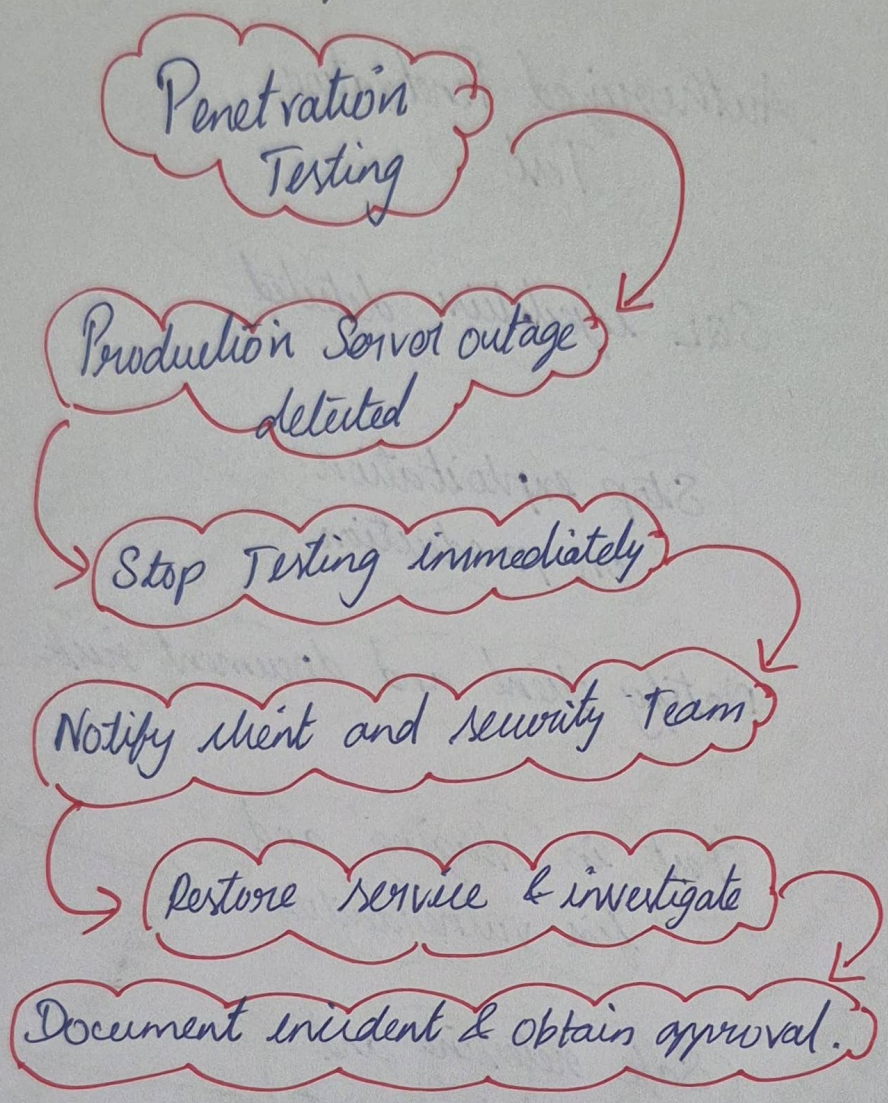
Prevention:

(i) Cap request rates and thread counts (--rate-limit, -T3 or lower)

(ii) Ban high-concurrency fuzzing and heavy, unindexed queries on production assets.

(iii) Restrict invasive tests to monitored, off peak maintenance windows

(3) D.S incident Response process



Ethical Responsibility :

The penetration tester must prioritize service availability, minimize harm, communicate honestly and take responsibility for accidental disruptions.
Testing must not resume until the client authorizes it.

4) Covert Testing without IT knowledge

Risks

↳ Wasted incident response : IT/Blue teams mistake the test for a real attack, burning critical emergency resources or pulling systems offline.

↳ Legal/ISP Blowback : Unaware defenders may report your IPs to law enforcement, hosting providers, or ISPs, causing black listing or account bans.

↳ Fog of War : A real threat actor striking simultaneously would be masked or misattributed to your activity.

Protective Safegaurds :

Executive authorization : Secured a signed "Get out of Jail Free" letter from C-level leadership (CEO, CISO)

Trusted Agent (white cell) : Assign one senior stakeholder aware of the test monitor activity and confirm identity during escalations.

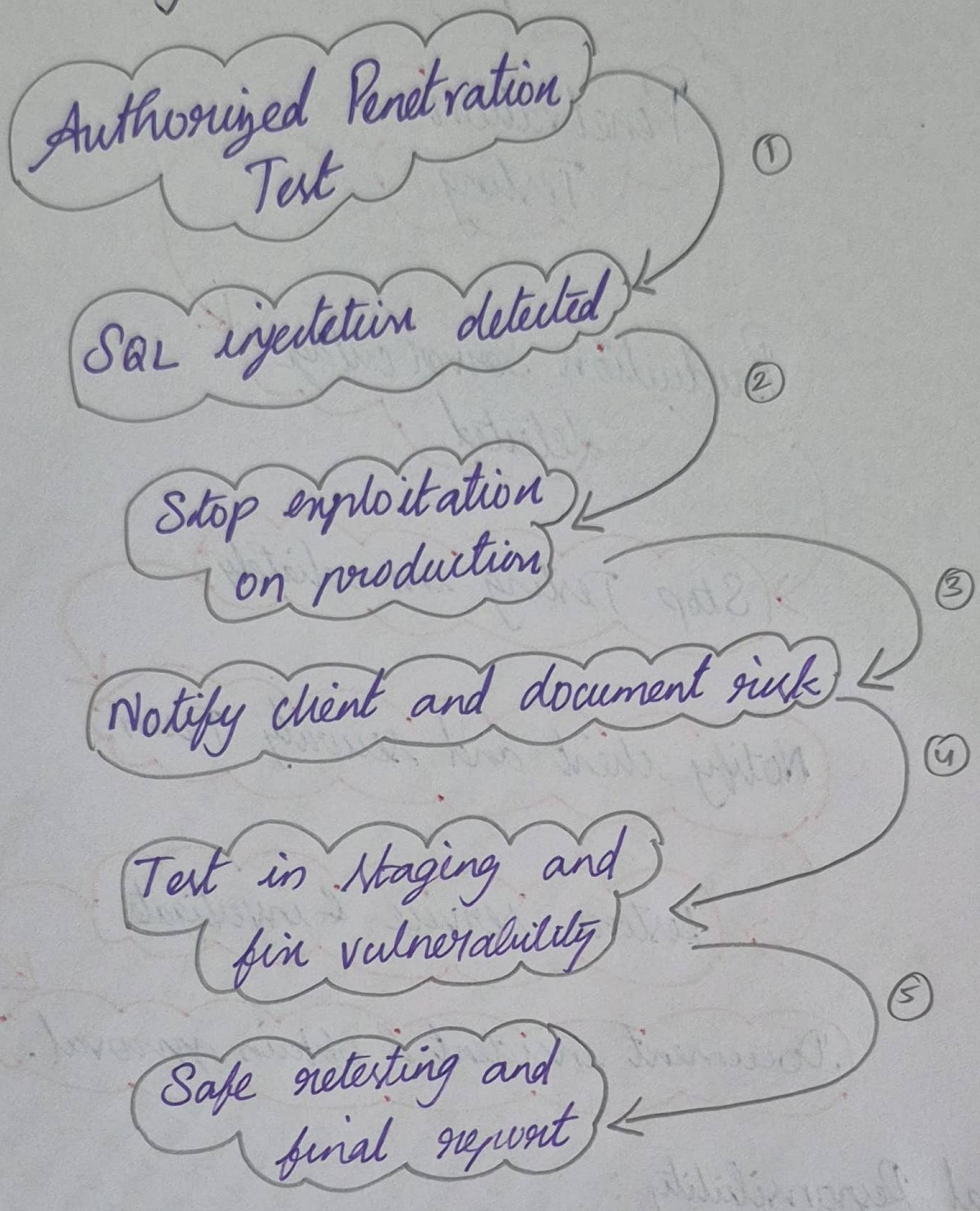
Static source IPs : Test exclusively from dedicated pre-declared IPs so logs can immediately distinguish your activity from real attackers.

Instant Abort protocol : Establish emergency code words and direct phone contacts to halt the engagement immediately if needed.

5) Red Team Exercise vs Vulnerability Assessment : Bank scenario

ASPECT	VULNERABILITY (VA)	RED TEAM EXERCISE
Goal	Find and catalog as many flaws as possible (breadth)	Reach a specific target like a real attacker (depth)
Approach	automated scans, audits and checklists.	phishing, chained exploits and lateral movements.
Physical Scope	Inspect locks, test badge readers and review CCTV with staff	Tailgate through doors, clone employee badges and plant rogue devices
Digital Scope	Automated port/patch scans across all public IPs and banking APPs	Spear-phish staff, evade end point detection and pivot toward core banking / SWIFT Networks
Rules & Awarness	IT/SOC are informed and assist during pre-set maintenance windows	IT/SOC are unaware; Overseen only by a small trusted executive "white cell" with strict no-go limits.

Q2) SQL Injection Testing Process



Ethical justification

Even with permission to coduct a penetration test, accessing real customer financial data or causing damage is not automatically authorized. Testing must remain within agreed scope and minimize harm.